

Design and Evaluation of a Security Hardening Framework for Cloud Object Storage

Group 4: Buddhita C., Nithin N., Spoogmy A., and John D. I.

AIT 670 – 001: Professor O. Cheche Agada

Introduction

Cloud storage services such as Amazon S3 are widely used for storing and managing data due to their scalability and accessibility. However, misconfigurations in cloud environments remain one of the leading causes of security breaches, often resulting in unauthorized access and data exposure. This project focuses on analyzing and improving the security of an S3-based storage system by identifying vulnerabilities and applying structured security controls.

The objective of this work is to evaluate a baseline insecure configuration, identify potential threats, and implement a security hardening framework based on established standards. By combining practical implementation with structured analysis, this project demonstrates how common cloud security risks can be effectively mitigated.

Methodology

This project consists of five main phases. First, a threat modeling phase was performed using the STRIDE framework and OWASP Threat Dragon to identify and categorize security threats across system components and data flows. Next, a baseline security assessment was conducted by intentionally configuring an insecure S3 bucket to observe potential vulnerabilities, such as public access exposure and weak access controls.

Based on the identified risks, a security framework design was developed by mapping controls to NIST CSF 2.0 and CIS AWS benchmarks, ensuring alignment with industry best practices. Then, these controls were applied in the implementation phase, where security mechanisms such as IAM least privilege, S3 access restrictions, encryption, and logging were enforced. Finally, the effectiveness of the implementation was evaluated by comparing the system's security posture before and after applying these controls.

1. Threat Modeling

To systematically identify potential security risks in the proposed cloud storage system, a threat modeling approach based on the STRIDE framework was applied. This phase analyzes threats across system components and data flows to provide a structured understanding of vulnerabilities in the baseline configuration.

A data flow diagram (DFD) was constructed using OWASP Threat Dragon to represent interactions between key components, including users, IAM, Amazon S3, and CloudTrail. As shown in Figure 1, the model highlights trusted and untrusted boundaries, as well as critical data flows such as authentication, authorized access, and logging events.

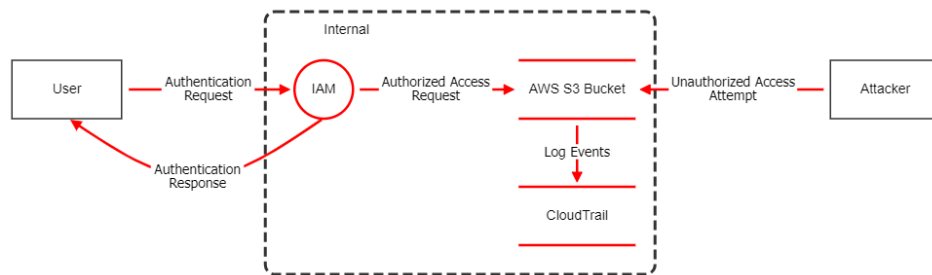


Figure 1 Illustrates the STRIDE-based threat model of the system

The STRIDE analysis identified a total of 26 potential threats across the system. A detailed breakdown is provided in an external reference (linked in the references section); therefore, this section focuses on the most critical risks.

The most significant risk is Information Disclosure in Amazon S3, where misconfigured bucket policies and disabled public access controls may expose sensitive data. This aligns with the baseline configuration, where public read access allowed unrestricted data retrieval. Additionally, Elevation of Privilege in IAM was identified due to overly permissive policies, and Repudiation risks arise from the lack of logging in the baseline configuration.

Other threats, such as tampering and denial of service, were also identified but are considered secondary, as this project focuses on risks related to S3 misconfiguration and data exposure.

2. Baseline Security Assessment

This part of the project focuses on evaluating the initial security setup of an Amazon S3 bucket before any hardening or security improvements are applied. The goal is to intentionally create a weak or insecure configuration and observe the risks that come with it. This helps show how data can be exposed when proper security controls are not in place. In real world environments, these kinds of misconfigurations can lead to unauthorized access or data leaks. This baseline setup is used as a reference point for comparing later improvements.

To begin, an S3 bucket named “baseline-insecure-bucket” was created using the AWS. The default region and settings were used during setup, and no advanced security features were enabled initially. After creating the bucket, the public access settings were modified so that the bucket was not fully protected. Specifically, the “Block all public access” option was turned off, which allows the possibility of public access if permissions are configured incorrectly, as shown in Figure 2. This step is important because it exposes the bucket to external users.

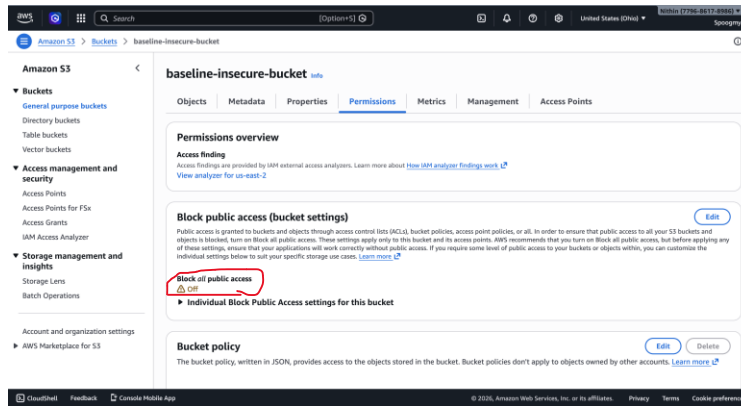


Figure 2 Block Public Access

Next, a bucket policy was applied to allow public read access to the objects stored in the bucket. The policy included a statement with "Principal": "*" and the s3:GetObject action, which allows anyone on the internet to read objects without authentication. This is considered an insecure configuration because it removes access restrictions. In a real world scenario, this could expose sensitive data to anyone with the object URL. The policy was intentionally set this way to demonstrate how misconfigurations can create vulnerabilities, as shown in Figure 3.

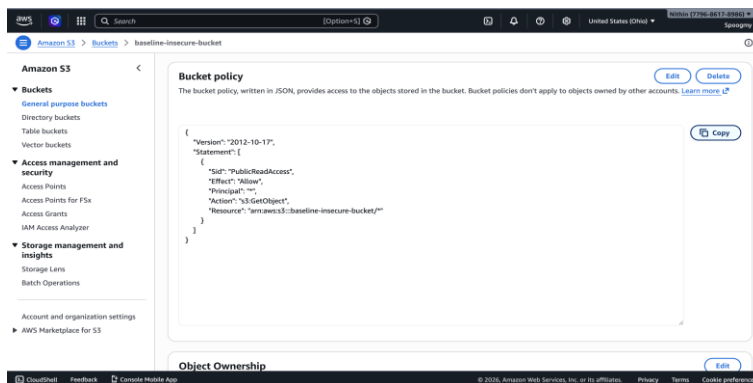


Figure 3 Bucket policy showing public read access

After that, a test file named Test.docx was uploaded to the bucket. The file appeared correctly in the object list, confirming that the upload was successful. This file was used to test whether the access settings were working as expected. The file's name, size, and upload time were visible in the S3 console, showing that the bucket was functioning properly, as shown in Figure 4

The object URL for the file was then copied and opened in a web browser. The file was successfully downloaded without requiring any login or authentication. This confirms that the public access policy was applied correctly. However, it also shows a major security issue since anyone with the link can access and download the file. This demonstrates the risk of allowing public access to objects stored in S3, as shown in Figure 5.

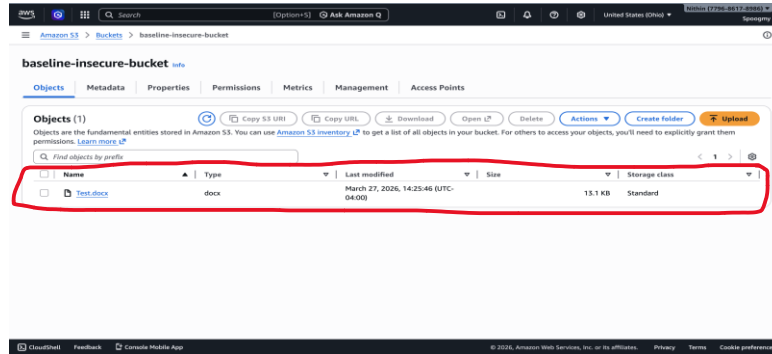


Figure 4 Objects tab showing Test.docx uploaded in the bucket

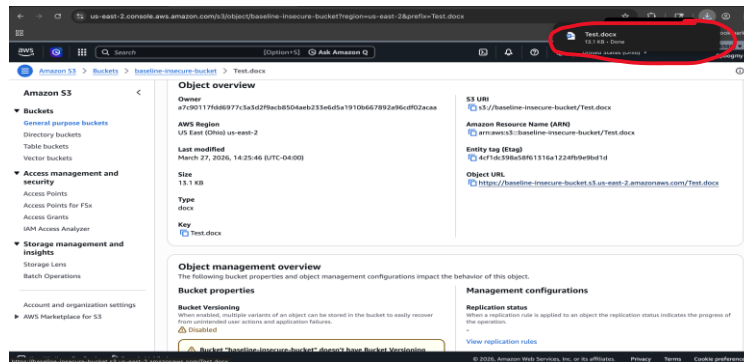


Figure 5 Object URL opened in browser showing file download or access result

The encryption settings of the bucket were also reviewed. The bucket uses server side encryption with Amazon S3 managed keys (SSE-S3), which provides basic encryption for data at rest. However, the bucket key feature was disabled, and AWS KMS was not used. This means the encryption is basic and does not include advanced key management or stronger security controls. More secure configurations would use customer managed keys and additional encryption policies, as shown in Figure 6.

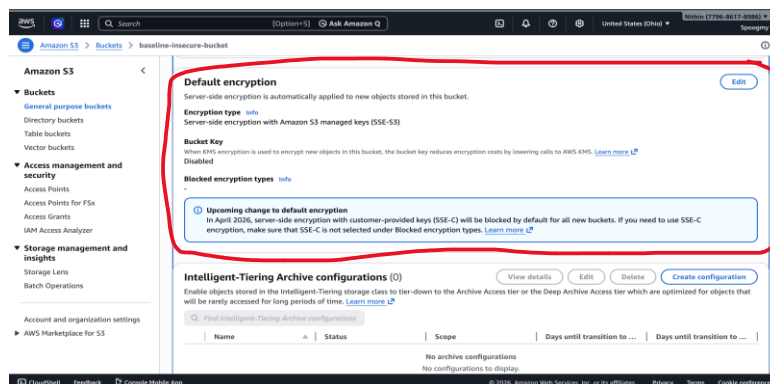


Figure 6 Default encryption settings showing SSE S3 and Bucket Key disabled

Overall, the baseline security assessment revealed several weaknesses in the bucket configuration. Public access was enabled, the bucket policy allowed unrestricted access, and encryption settings were minimal. There were also no logging, versioning, or monitoring features enabled. These issues make the bucket vulnerable to unauthorized access and data exposure. This baseline setup clearly shows why security hardening is necessary in cloud environments.

3. Framework Design

Based on the NIST CSF 2.0 and CIS AWS Benchmark, This project designs a structured security hardening framework for cloud object storage. The framework adopts a lifecycle-based approach to structure of security controls into several domains like access control, monitoring and detection, data protection, etc. It provides valuable insights into the standardization of security objectives, by mapping high-level security objectives to practical AWS implementations. This also has a measurable evaluation mechanism to assess the security posture improvements, which makes it systematic and scalable.

3.1 NIST-Based Architecture Diagram



Figure 7 NIST Diagram

3.2 Detailed NIST ↔ CIS ↔ AWS Mapping Table

Table 3.2.1. Identity & Access Control

Category	CSF 2.0	CIS AWS Benchmark	AWS Implementation
Identity Management	<u>PR.AA-01</u>	2.11, 2.12	IAM user/role management
Authentication	<u>PR.AA-03</u>	2.8 / 2.9	Enable MFA
Least Privilege	<u>PR.AA-05</u>	2.15	Remove "*" : "*" policies
Access Control	<u>PR.AA-05</u>	2.14	Use IAM groups/roles
Separation of Duties	<u>PR.AA-05</u>	2.17	Use IAM roles

Table 3.2.2 S3 Bucket Security

Category	CSF 2.0	CIS AWS Benchmark	AWS Implementation
Public Access Blocking	<u>PR.AA-05</u>	3.1.4	Enable Block Public Access
Secure Transport	<u>PR.DS-02</u>	3.1.1	Enforce HTTPS

Data Monitoring	<u>DE.CM-01</u>	4.8, 4.9	Enable CloudTrail + S3 logging
-----------------	-----------------	----------	--------------------------------

Table 3.2.3 Data Protection

Category	CSF 2.0	CIS AWS Benchmark	AWS Implementation
Data-at-Rest	<u>PR.DS-01</u>	3.2.1 / 6.1.1	Encryption enabled
Data Integrity	<u>PR.DS-01</u>	3.1.2	Versioning / MFA delete
Data-in-Transit	<u>PR.DS-02</u>	3.1.1	HTTPS enforced

Table 3.2.4 Logging & Monitoring

Category	CSF 2.0	CIS AWS Benchmark	AWS Implementation
Audit Logging	<u>DE.CM-01</u>	4.1	Enable CloudTrail
Log Integrity	<u>DE.CM-01</u>	4.2	Log validation
Continuous Monitoring	<u>DE.CM-01</u>	4.3	AWS Config
Event Monitoring	<u>DE.AE-02</u>	5.1–5.5	GuardDuty alerts

Table 3.2.5 Detection & Investigation

Category	CSF 2.0	CIS AWS Benchmark	AWS Implementation
Anomaly Detection	<u>DE.AE-02</u>	5.1	Monitor API calls
Event Correlation	<u>DE.AE-03</u>	5.8, 5.9	Detect changes
Log Analysis	<u>DE.CM-01</u>	4.8, 4.9	Analyze logs

Table 3.2.6 Response & Recovery

Category	CSF 2.0	CIS AWS Benchmark	AWS Implementation
Response Planning	<u>RS.MA-01</u>	2.16	Support role setup
Mitigation	<u>RS.MI-01</u>	2.15, 3.1.4	Fix IAM/S3 issues
Recovery	<u>RC.RP-01</u>	General remediation	Re-secure resources

3.3 SPS

Security Posture Score (SPS) is a quantitative metric used to evaluate the overall security level of a cloud environment based on key NIST CSF 2.0 domains, providing a standardized way to measure the effectiveness of implemented security controls.

Table 3.2.7 Domains and Scoring:

Domain	CSF 2.0 Category	Abbreviation	Score Range
Identity & Access Control	PR.AA	AA	0 – 2
Data Security	PR.DS	DS	0 – 2
Continuous Monitoring	DE.CM	CM	0 – 2
Detection & Analysis	DE.AE	AE	0 – 2

Scoring Criteria / Formula:

Score	Description
0	Not Implemented
1	Partially Implemented
2	Fully Implemented

$$\text{SPS (\%)} = (\text{AA} + \text{DS} + \text{CM} + \text{AE}) / 8 \times 100$$

4. Implementation

Here it describes the practical application of the proposed security hardening framework to an initially insecure Amazon S3 environment. The objective of this phase is to systematically apply security controls based on NIST CSF 2.0 and CIS AWS benchmarks, transforming the baseline configuration into a secure and controlled state. The implementation focuses on four domains: access control, data security, monitoring, and detection. Each control is applied in a structured manner to eliminate identified vulnerabilities and reduce the risk of unauthorized access or data exposure.

4.1 Access Control Hardening

The initial configuration allowed overly permissive access, which is a common cause of cloud security breaches. To address this, strict identity and access management controls were implemented. First, all excessive permissions such as full administrative access to S3 were removed. A new IAM group was created with a custom inline policy that restricts actions to only essential operations, specifically object upload and retrieval. This enforces the principle of least privilege, ensuring that users can only perform necessary tasks. Additionally, users were assigned to this group instead of being granted direct permissions, improving manageability and separation of duties. Multi-factor authentication (MFA) was also considered as part of secure authentication practices. As a result, unauthorized actions such as object deletion or bucket modification were successfully restricted, demonstrating effective access control enforcement.

4.2 S3 Bucket Security Hardening

In the baseline setup, the S3 bucket was publicly accessible due to disabled public access settings and a permissive bucket policy. This exposed stored data to external users. To mitigate this risk, all public access settings were enabled using the “Block Public Access” feature. The previously configured public-read bucket policy was removed, ensuring that no anonymous user could access the bucket contents. This change immediately eliminated external exposure. When tested using the object URL, access was denied, confirming that the bucket was no longer publicly accessible, shown in Figure 8. In Figure 9, the access was from a valid user but with no privileges to modify the object in the bucket.

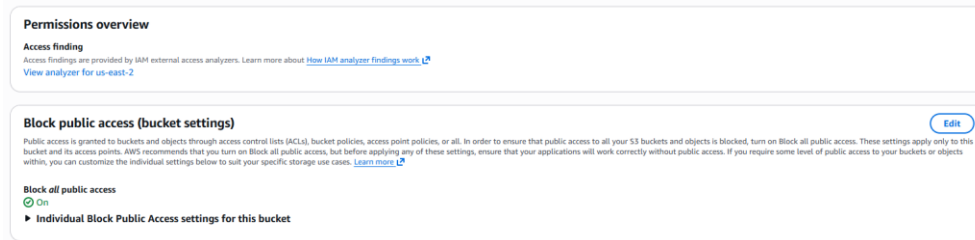


Figure 8 Block of public access

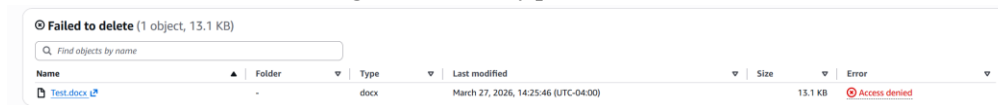


Figure 9 Fail to perform actions on the objects in the bucket.

4.3 Data protection and Encryption

Encryption and integrity controls were implemented here, The bucket’s default encryption was upgraded from basic server-side encryption (SSE-S3) to AWS Key Management Service (SSE-KMS). This provides enhanced control over encryption keys and aligns with industry best practices for protecting sensitive data at rest shown in Figure 10. Versioning was also enabled to ensure data integrity. This allows multiple versions of an object to be retained, preventing accidental or malicious data loss. Testing confirmed that multiple versions of the same file were preserved after repeated uploads shown in Figure 11 and 12. Additionally, a secure transport policy was introduced to enforce encrypted communication. This policy denies any requests made over insecure HTTP, ensuring that all data transfers occur over HTTPS shown in Figure 13.

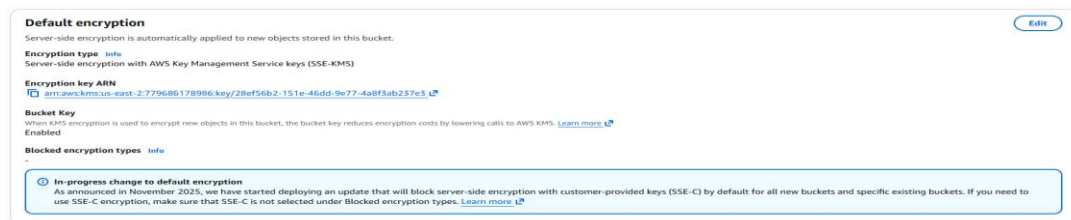


Figure 10 SSE-KMS encryption

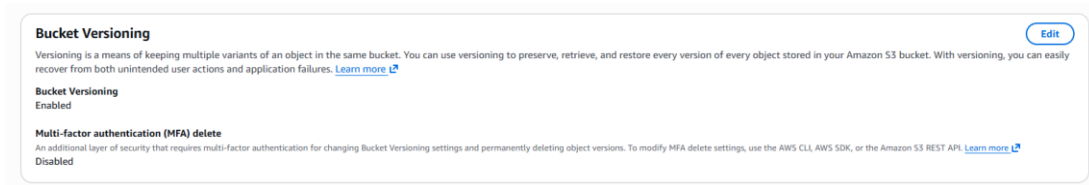


Figure 11 Bucket versioning

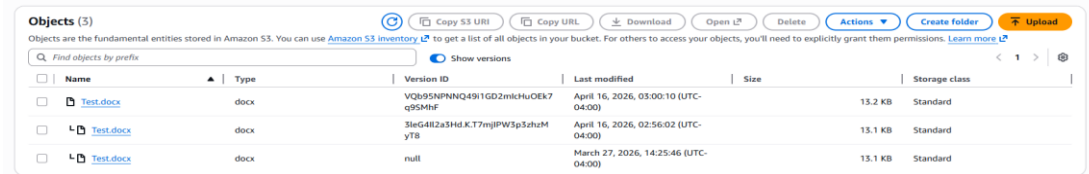


Figure 12 Object Versioning

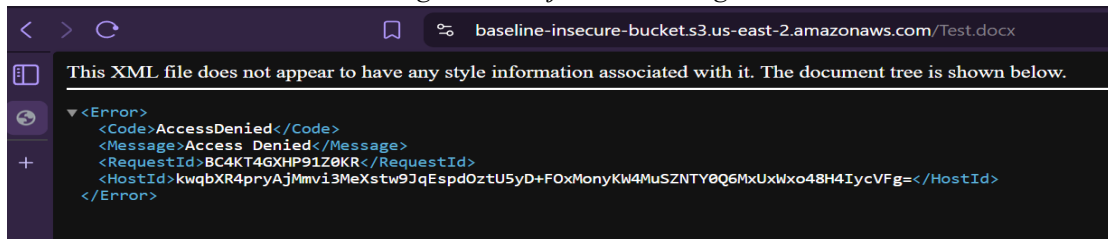


Figure 13 Unable to access Object via HTTP

4.4 Logging and Monitoring

Visibility into system activity is critical for detecting and responding to security incidents. In the baseline setup, no logging mechanisms were enabled, resulting in a lack of auditability. To address this, AWS CloudTrail was configured to capture both management and S3 data events. This allows tracking of actions such as object uploads, downloads, and deletions. After enabling CloudTrail, test activities were performed and successfully recorded in the logs, confirming proper functionality shown in Figure 14. In addition, S3 server access logging was enabled by configuring a separate log bucket. This provides detailed records of access requests made to the S3 bucket, further enhancing monitoring capabilities. AWS Config was also considered to track configuration changes, ensuring continuous monitoring of the environment.

PutBucketPolicy	April 16, 2026, 11:15:57 (UTC-04:00)	root	s3.amazonaws.com	AWS::S3::Bucket	baseline-insecure-bucket
UpdateTrail	April 16, 2026, 11:15:57 (UTC-04:00)	root	cloudtrail.amazonaws.com	AWS::CloudTrail::Trail	S3-Bucket-Trial, arn:aws:cloudtrail:us-east-2:779686178986:trail/S3-Bucket-Trial
PutEventSelectors	April 16, 2026, 03:38:14 (UTC-04:00)	root	cloudtrail.amazonaws.com	AWS::CloudTrail::Trail	arn:aws:cloudtrail:us-east-2:779686178986:trail/S3-Bucket-Trial
PutEventSelectors	April 16, 2026, 03:37:24 (UTC-04:00)	root	cloudtrail.amazonaws.com	AWS::CloudTrail::Trail	arn:aws:cloudtrail:us-east-2:779686178986:trail/S3-Bucket-Trial
PutEventSelectors	April 16, 2026, 03:36:47 (UTC-04:00)	root	cloudtrail.amazonaws.com	AWS::CloudTrail::Trail	arn:aws:cloudtrail:us-east-2:779686178986:trail/S3-Bucket-Trial
StartLogging	April 16, 2026, 03:34:38 (UTC-04:00)	root	cloudtrail.amazonaws.com	AWS::CloudTrail::Trail	arn:aws:cloudtrail:us-east-2:779686178986:trail/S3-Bucket-Trial

Figure 14 Logs of actions on the object.

4.5 Detection Layer

As part of the framework, AWS GuardDuty was identified as the primary tool for threat detection and anomaly analysis. GuardDuty integrates with CloudTrail logs to identify suspicious behaviour such as unauthorized access attempts or unusual API activity. However, due to AWS account activation limitations, GuardDuty could not be fully enabled during the implementation phase. Despite this constraint, the detection layer remains a critical component of the overall framework design and is included as part of the proposed security architecture.

5. Comparison

To evaluate the effectiveness of the implemented controls, a comparison was conducted between the baseline and hardened S3 configurations using the Security Posture Score (SPS). In the baseline state, all domains as Identity & Access Control, Data Security, Continuous Monitoring and Detection & Analysis are scored 0, resulting in an SPS of 0%. The bucket was publicly accessible, permissions were overly permissive, and logging was absent, exposing the system to significant risks.

After implementation, notable improvements were observed. Identity & Access Control, Data Security and Continuous Monitoring each improved from 0 to 2 through least privilege enforcement, SSE-KMS encryption, versioning, and CloudTrail logging. These changes eliminated public access, strengthened data protection, and enabled full activity visibility. Detection & Analysis remained at 0 due to GuardDuty limitations. However, the overall SPS increased to 75%, demonstrating a significant enhancement in security posture and reduced exposure to common cloud threats.

Conclusion

This project demonstrates how a structured security approach can significantly improve the protection of cloud storage systems. The baseline assessment revealed critical vulnerabilities, particularly related to public access, insufficient access control, and lack of monitoring. Through STRIDE-based threat modeling, these risks were systematically analyzed and prioritized.

The implementation of security controls based on NIST and CIS guidelines effectively mitigated the most critical threats, including information disclosure, privilege escalation, and lack of auditability. As a result, the system's overall security posture was significantly enhanced. This study highlights the importance of combining threat modeling with practical implementation to achieve a comprehensive and effective cloud security strategy.

References

1. AIT 650 Labs
2. Amazon Web Services, "What is Amazon S3?," *Amazon S3 User Guide*. [Online]. Available: <https://docs.aws.amazon.com/AmazonS3/latest/userguide/Welcome.html>
3. NIST, "NIST Cybersecurity Framework (CSF) 2.0," *CSF.tools*. [Online]. Available: <https://csf.tools/reference/nist-cybersecurity-framework/v2-0/>
4. Center for Internet Security, "Center for Internet Security," [Online]. Available: <https://www.cisecurity.org/>
5. OWASP Foundation, "OWASP Threat Dragon," [Online]. Available: <https://owasp.org/www-project-threat-dragon/>
6. https://drive.google.com/file/d/1EBE0oaOZXgDmJn-YAXqHciNtp4otv4TA/view?usp=drive_linkswha